

# Does Random Mean Secure?

Randomness, Predictability and Information Leakage

tdvnm

Probability and Statistics project

September 17, 2026

## RANDOMNESS

## Can we actually make something random?

Try it: write down 10–15 zeros and ones, as randomly as you can.

101001011010010

- Did you deliberately balance the zeros and ones?
- Did you avoid 0000 or 1111?
- Did you alternate more than a coin would?

Our sense of what *looks* random is not a probability model.  
So what should a genuinely random source actually do?

## RANDOMNESS

# So what should a random sequence actually do?

Model the source as bits  $B_1, \dots, B_n \in \{0, 1\}$ .

## Fairness

No preference for 0 or 1.

$$\mathbb{P}(B_i = 1) = \mathbb{P}(B_i = 0) = \frac{1}{2}$$

## Independence

Knowing earlier bits does not help predict the next one.

$$\mathbb{P}(B_{i+1} = 1 \mid B_1, \dots, B_i) = \mathbb{P}(B_{i+1} = 1)$$

### Two ways this can fail

**Bias.** The probabilities of 0 and 1 are wrong.

**Dependence.** The counts may look fine, but the bits influence one another.

Under this model every  $n$ -bit string has probability  $2^{-n}$ . A test compares the data against exactly that.

## TESTING · FREQUENCY TEST

**Half zeros and half ones is not enough**

Both strings have eight zeros and eight ones.

0000000011111111  
0101010101010101

The frequency is right in both. The pattern clearly is not.

Count the ones:

$$X = \sum_{i=1}^n B_i$$

Under independent fair bits,

$$X \sim \text{Bin}(n, \tfrac{1}{2}).$$

The frequency test asks

Is the observed number of ones unusual under the fair-bit model?

It cannot see order at all. A correct frequency does not imply independence.

## TESTING · RUNS TEST

**Two tests ask two different questions**

Frequency measures balance. Runs measure pattern.

A *run* is a maximal block of equal bits:

00**111**00  $\rightarrow$  00 | **111** | 00      three runs

$$R = 1 + \#\{\text{switches } B_i \neq B_{i+1}\}$$

Each of the  $n - 1$  neighbouring pairs switches independently with probability  $\frac{1}{2}$ , so

$$R - 1 \sim \text{Bin}(n - 1, \tfrac{1}{2}).$$

**Frequency test**

Is the balance of zeros and ones unusual?

**Runs test**

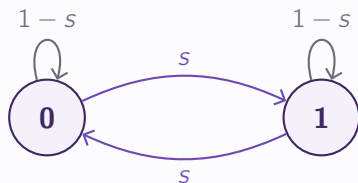
Is the amount of switching or repeating unusual?

Two sequences can share a frequency and still differ completely in dependence.

## TESTING · RUNS TEST

# What if randomness has memory?

A source whose next bit depends only on its current bit.



$$P = \begin{pmatrix} 1-s & s \\ s & 1-s \end{pmatrix}$$

$s$  = probability of switching

$s = 0.5$  the current bit says nothing about the next: independent fair bits.

$s = 0.8$  the next bit is probably the opposite of this one.

Started symmetrically, both keep roughly half zeros and half ones. Only the switching changes:  
 $\mathbb{E}[R] = 1 + (n-1)s$ .

50/50 does not imply independence. The frequency test passes; the runs test is the one that notices.

## PREDICTABILITY · PSEUDORANDOM GENERATORS

# Looking random is not the same as being unpredictable

A  $p$ -value asks: *if the ideal model were true, how unusual would a statistic this extreme be?* Small: evidence against the model. Large: this test found nothing. That is not proof of security.

## Statistical question

Does the observed output behave like the probability model?

A pseudorandom generator is a deterministic rule on a hidden state,

$$S_{n+1} = f(S_n), \quad B_n = g(S_n).$$

Its output can look convincing on a finite sample; recover the state and every future bit is fixed. Cryptographic generators (Linux's `getrandom()`) are deterministic after seeding too; their design goal is that prediction is infeasible. Passing tests does not show that.

## Security question

Can someone predict future output, or recover the generator's state?

## SECRECY · XOR

# What happens when randomness becomes a key?

So far, predictability was a property of a sequence. Now use the bits as a key.

$$C = M \oplus K$$

|            |     |
|------------|-----|
| Message    | 0 1 |
| Key        | 1 0 |
| <hr/>      |     |
| Ciphertext | 1 1 |

XOR is its own inverse, so the receiver applies the same key again:

$$11 \oplus 10 = 01.$$

## Why two bits

Four messages, four keys, four ciphertexts.  
The whole probability model is a  $4 \times 4$  table, so everything that follows is an exact calculation, not an estimate.

The attacker sees  $C$  and knows the rule and the distributions of  $M$  and  $K$ , but not the key that was used.



## SECRECY · PERFECT SECREC

## When does the ciphertext tell us nothing?

Seeing the ciphertext should not change what the attacker believes.

$$\mathbb{P}(M = m \mid C = c) = \mathbb{P}(M = m)$$

Take a uniform, independent two-bit key:

$$\mathbb{P}(K = 00) = \mathbb{P}(01) = \mathbb{P}(10) = \mathbb{P}(11) = \frac{1}{4}.$$

For any message  $m$  and ciphertext  $c$  there is exactly one key that connects them,  
 $k = m \oplus c$ . So

$$\mathbb{P}(C = c \mid M = m) = \mathbb{P}(K = m \oplus c) = \frac{1}{4}$$

for every  $m$ .

Then Bayes' rule finishes it

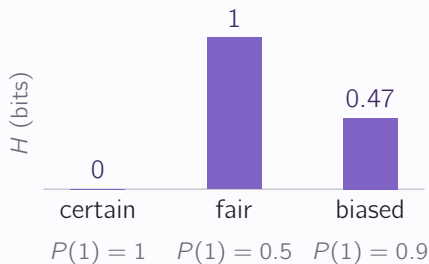
The likelihood  $\mathbb{P}(C = c \mid M = m)$  is the same for every  $m$ , so it cancels: the posterior equals the prior.

Every message explains every ciphertext equally well, so the ciphertext says nothing about which one was sent.

## SECURITY · ENTROPY · INFORMATION LEAKAGE

## How do we measure what gets revealed?

Entropy is uncertainty, in bits. Leakage is how much of it disappears.



$H(M)$ : uncertainty about the message before seeing anything.

$H(M | C)$ : uncertainty that remains after seeing the ciphertext.

$$I(M; C) = H(M) - H(M | C)$$

### Mutual information

How much the ciphertext reduces the attacker's uncertainty about the message.  $I(M; C) = 0$ : nothing leaked, perfect secrecy.

## EXPERIMENT · EXPERIMENT

# What if I change only the randomness?

Same cipher, same messages. Only the key distribution moves.

## Kept fixed

- $\mathbb{P}(M = 00, 01, 10, 11) = (0.4, 0.3, 0.2, 0.1)$
- $C = M \oplus K$ , key independent of  $M$

## Changed

- $K_1, K_2$  independent  $\text{Bern}(q)$
- $q = 0.50, 0.55, \dots, 0.95$

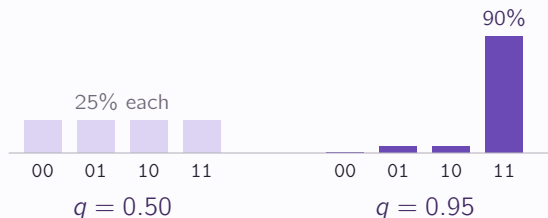
At  $q = 0.5$  this is the uniform key of the perfect-secrecy slide. As  $q$  grows the key bits still ignore each other; each just leans towards 1.

A different failure from the Markov source: that example had *dependence* with fair counts. Here the key bits stay independent and we turn up the *bias*.

## EXPERIMENT · EXPERIMENT

# As the key becomes predictable, secrecy begins to disappear

At  $q = 0.95$  one key shows up nine times out of ten.



Key entropy  $H(K) = 2h(q)$ , with  $h$  the entropy of one  $\text{Bern}(q)$  bit, falls from 2 bits to 0.57 bits.

## One ciphertext, $q = 0.95$ , $C = 11$



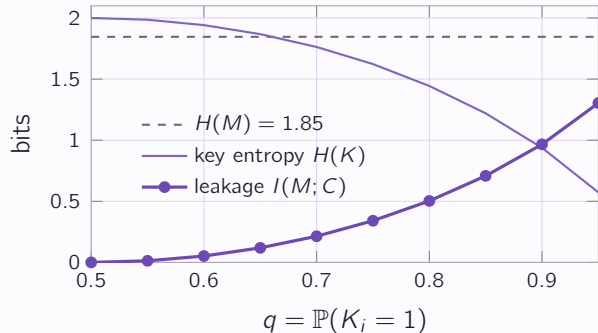
Before: “00” with probability 0.40. After seeing 11: 0.94, because the key was almost surely 11.

**The ciphertext changed the attacker’s belief. That change is the leakage we measure.**

## EXPERIMENT · RESULTS

# The weaker the key, the more the ciphertext reveals

Exact calculation. Cipher and messages unchanged; only the key distribution moved.



$$q = 0.50 \quad H(K) = 2, \quad I(M; C) = 0.$$

$$q = 0.95 \quad H(K) \approx 0.57, \\ I(M; C) \approx 1.30 \text{ of the 1.85 bits in } M.$$

For XOR with an independent key,  
 $I(M; C) = H(C) - H(K)$ .

A result for *this* cipher, message distribution and key family. Key entropy alone does not decide security in general.

## EXPERIMENT · RESULTS

## Checking the curve by simulation

Planned validation. The plot on the previous slide is theory, not measurement.

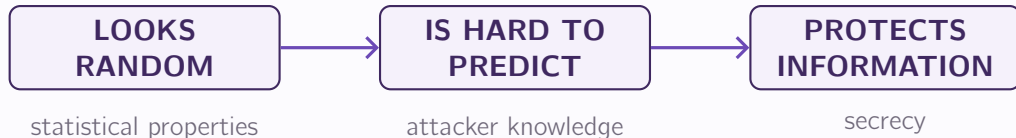
For each  $q$ :

- 1 sample messages from  $(0.4, 0.3, 0.2, 0.1)$
- 2 sample independent  $\text{Bern}(q)$  key bits
- 3 compute  $C = M \oplus K$
- 4 repeat about 10,000 times and count the  $(M, C)$  pairs
- 5 estimate  $I(M; C)$  from the counts
- 6 compare with the exact curve

A plug-in estimate from a finite table has sampling error and a small upward bias, so at  $q = 0.5$  it should sit slightly above zero and shrink as the sample grows. No simulated points exist yet.

## EXPERIMENT · CONCLUSION

## Does random mean secure?



- Balanced output does not mean independence.
- Passing a few statistical tests does not establish unpredictability.
- Once the randomness is a key, predictability turns into information leakage.

**Good randomness is necessary for secrecy,  
but looking random is not enough to establish security.**

## BACKUP

**Backup: what a  $p$ -value actually says**

For an observed statistic  $t$  under the null model  $H_0$  (independent fair bits):

$$p = \mathbb{P}(T \text{ at least as extreme as } t \mid H_0)$$

- Small  $p$ : data of this kind would be rare if  $H_0$  held. Evidence against  $H_0$ .
- Large  $p$ : this statistic did not detect a departure on this sample.
- It is not  $\mathbb{P}(H_0 \mid \text{data})$ , and it says nothing about what an attacker can compute from the output.

For the frequency test,  $T = X \sim \text{Bin}(n, \frac{1}{2})$ ; for the runs test,  $T = R - 1 \sim \text{Bin}(n - 1, \frac{1}{2})$ . Both are two-sided. Standard batteries such as NIST SP 800-22 collect many such statistics.



## BACKUP

## Backup: the two-state Markov source

**Markov property.**  $\mathbb{P}(B_{i+1} = b \mid B_1, \dots, B_i) = \mathbb{P}(B_{i+1} = b \mid B_i)$ : the future depends on the past only through the present bit.

$$P = \begin{pmatrix} 1-s & s \\ s & 1-s \end{pmatrix}, \quad P_{ab} = \mathbb{P}(B_{i+1} = b \mid B_i = a).$$

- Start with  $\mathbb{P}(B_1 = 1) = \frac{1}{2}$ . By symmetry of  $P$ , every  $B_i$  is  $\text{Bern}(\frac{1}{2})$ , so the frequency statistic still has mean  $n/2$ .
- Each neighbouring pair switches independently with probability  $s$ , so  $R - 1 \sim \text{Bin}(n - 1, s)$  and  $\mathbb{E}[R] = 1 + (n - 1)s$ .
- A natural estimate is  $\hat{s} = (R - 1)/(n - 1)$ .

Blitzstein and Hwang, *Introduction to Probability*, Ch. 11, for the Markov property and transition matrix. Nothing more of the chapter is needed here.

## BACKUP

**Backup: the posterior at  $q = 0.95$ ,  $C = 11$** 

Key probabilities:  $\mathbb{P}(K = 00) = 0.0025$ ,  $\mathbb{P}(01) = \mathbb{P}(10) = 0.0475$ ,  $\mathbb{P}(11) = 0.9025$ . The key that maps  $m$  to  $c = 11$  is  $m \oplus 11$ .

| $m$                  | $\mathbb{P}(M = m)$ | $\mathbb{P}(K = m \oplus 11)$ | product |
|----------------------|---------------------|-------------------------------|---------|
| 00                   | 0.40                | 0.9025                        | 0.3610  |
| 01                   | 0.30                | 0.0475                        | 0.01425 |
| 10                   | 0.20                | 0.0475                        | 0.0095  |
| 11                   | 0.10                | 0.0025                        | 0.00025 |
| $\mathbb{P}(C = 11)$ |                     |                               | 0.3850  |

$$\mathbb{P}(M = 00 \mid C = 11) = \frac{0.3610}{0.3850} \approx 0.938, \quad \text{versus the prior } 0.40.$$

Bayes' rule with the law of total probability in the denominator.

## BACKUP

**Backup: a small deterministic generator**

A linear congruential generator:

$$X_{n+1} = (aX_n + c) \bmod m, \quad B_n = X_n \bmod 2$$

- The whole future is fixed by the state  $X_n$  and the constants  $(a, c, m)$ .
- With a small  $m$  an attacker can try every state and match the observed bits; from then on nothing is unknown.
- Its output may still look balanced and switch a reasonable amount on a short sample. That is the gap between passing a test and being unpredictable.

Cryptographic generators are also deterministic after seeding. The difference is a design goal: recovering the state or predicting the next bit should be computationally infeasible.

## BACKUP

# References

- J. K. Blitzstein and J. Hwang, *Introduction to Probability*, 2nd ed. Bernoulli and Binomial distributions, conditional probability, Bayes' rule, Markov property.
- C. E. Shannon, "A Mathematical Theory of Communication," 1948. Entropy and mutual information.
- C. E. Shannon, "Communication Theory of Secrecy Systems," 1949. Perfect secrecy.
- NIST SP 800-22 Rev. 1a, 2010. Statistical test suite for random and pseudorandom number generators.